

# System Security Plan

## Atlas Logistics Risk Platform (ALRP)

Prepared by: Maria Chen, ISSO

Baseline: NIST SP 800-53 Rev. 5 -- Moderate

Classification: Controlled Unclassified Information (CUI)

Status: Draft for pre-adjudication review

### 1. System Identification

The Atlas Logistics Risk Platform (ALRP) is a Moderate-impact information system operating within an approved AWS GovCloud environment. It ingests supplier financial filings, delivery performance data, and open-source intelligence to produce a composite supplier-risk score in support of Defense Logistics Agency procurement decisions. The system processes Controlled Unclassified Information and does not process classified information.

### 2. Authorization Boundary

The authorization boundary comprises the ALRP web application, the supplier-risk scoring engine, the managed relational database, the evidence object store, and the administrative interface. Platform services inherited from the cloud service provider are documented as inherited controls and are out of scope for re-assessment in this plan.

### 3. Control Implementations

#### AC-2 Account Management

Account management governs the full lifecycle of identities that can access the system, from provisioning through disablement.

Privileged, standard, and service accounts are reviewed monthly by the ISSO to confirm continued need and least-privilege alignment.

Provisioning is initiated from an approved request and enforced through the enterprise identity provider; the ISSO is accountable for the control.

#### AC-6 Least Privilege

The principle of least privilege constrains each role to the minimum set of permissions required to perform its function.

Least-privilege role assignments are recertified annually by the ISSO together with the system owner.

Role definitions are maintained in the identity provider and mapped to documented job functions.

#### AT-2 Literacy Training and Awareness

Security literacy ensures that every individual with access understands their responsibilities and the threats relevant to their role.

Role-based security awareness training is delivered to all personnel annually, with completion tracked in the learning management system.

Curricula are tailored to general users, privileged users, and incident responders, and completion is a condition of continued access.

### **AU-11 Audit Record Retention**

Audit retention preserves the evidentiary record required for after-the-fact investigation and accountability.

Audit-retention configuration and storage integrity are validated annually against the documented policy.

Records are written to an immutable, access-controlled store with integrity protection enabled.

### **CA-7 Continuous Monitoring**

Continuous monitoring maintains ongoing awareness of the security posture in support of risk-based authorization decisions.

The continuous-monitoring control sample is assessed monthly and the results reported to the Authorizing Official.

Findings are tracked to closure in the plan of action and milestones and summarized for the Authorizing Official.

### **CM-8 System Component Inventory**

An accurate component inventory is the foundation for vulnerability management, license control, and incident scoping.

The authoritative system inventory is reconciled quarterly against the assets discovered on the network.

Discovery data is collected automatically and reconciled against the authoritative inventory of record.

### **IR-6 Incident Reporting**

Timely incident reporting satisfies regulatory obligations and enables coordinated response across the enterprise.

Confirmed incidents are reported to the designated authorities weekly and recorded in the incident-tracking system.

Reports follow the severity-based escalation matrix and are delivered through the designated reporting channel.

### **RA-5 Vulnerability Monitoring and Scanning**

Vulnerability scanning identifies exploitable weaknesses before an adversary can leverage them.

Authenticated vulnerability scans are executed weekly across every asset inside the authorization

boundary.

Scan results are risk-ranked and remediated within timelines keyed to severity, with exceptions formally accepted.

## **4. Supporting Controls**

### **PL-2 System Security Plan**

This plan documents the security controls selected for the system and the rationale for their selection. It is reviewed and updated as the system or its environment changes.

### **CA-2 Control Assessments**

Selected controls are assessed by an independent assessor, and the resulting findings are tracked to closure in the plan of action and milestones.